

BTS SIO — Option SISR

Année 2025 / 2026

VEILLE TECHNOLOGIQUE

Ransomwares nouvelle génération et intelligence artificielle

« Comment l'intelligence artificielle fait-elle évoluer les ransomwares et quelles stratégies les entreprises doivent-elles adopter pour s'en protéger ? »

Réalisé par : Ennar Mehdi

Formation : BTS SIO — Option SISR

Matière : Veille technologique

Date : 03/09/2026

Introduction

Pour cette veille, j'ai choisi de suivre un sujet qui revient sans arrêt dans l'actualité cyber depuis deux ans : l'utilisation de l'intelligence artificielle par les groupes de ransomware. Ce n'est pas qu'un effet d'annonce — les rapports de l'ANSSI et de Sophos montrent que les méthodes d'attaque ont réellement changé de nature avec l'arrivée de l'IA générative.

Les ransomwares chiffrent les données d'une victime et réclament une rançon en échange de la clé de déchiffrement. En 2023 déjà, leur coût mondial dépassait les 30 milliards de dollars selon Sophos. Depuis 2022-2023, l'intégration de l'IA dans les outils des cybercriminels a accéléré ce phénomène : reconnaissance automatisée des cibles, phishing personnalisé, malwares optimisés, et déploiement d'attaques beaucoup plus rapide qu'avant.

Cette veille a pour but de comprendre comment l'IA transforme concrètement les ransomwares, d'observer quelques cas récents, et de présenter les stratégies de défense adaptées à cette évolution.

Problématique : « *Comment l'intelligence artificielle fait-elle évoluer les ransomwares et quelles stratégies les entreprises doivent-elles adopter pour s'en protéger ?* »

Méthode de recueil d'information

J'ai suivi ce sujet sur plusieurs semaines plutôt que de tout chercher d'un coup, pour voir l'actualité évoluer dans le temps. Mon flux principal a été daily.dev : je m'en sers au quotidien pour suivre l'actualité tech, et j'y ai configuré des filtres sur les mots-clés « ransomware », « RaaS » et « AI security » pour que les bons articles remontent automatiquement. C'est plus simple à tenir dans la durée qu'une recherche manuelle à chaque fois.

À côté de ce flux quotidien, j'ai croisé les informations avec des sources institutionnelles (ANSSI, CERT-FR) pour vérifier les chiffres, avec des rapports annuels d'éditeurs de sécurité (Sophos, Microsoft) pour les statistiques, et avec la presse spécialisée (ZATAZ, Bleeping Computer) pour l'actualité des attaques. Chaque chiffre repris dans ce rapport a été retrouvé dans au moins deux sources avant d'être gardé.

Partie 1 — L'évolution des ransomwares à l'ère de l'IA

Le fonctionnement de base n'a pas changé

Un ransomware classique suit toujours à peu près le même cycle : infection par email piégé ou vulnérabilité non corrigée, propagation latérale dans le réseau, chiffrement des fichiers avec des algorithmes robustes (AES-256, RSA-2048), puis demande de rançon en cryptomonnaie. Ce mécanisme de base n'a pas vraiment évolué depuis plusieurs années. Ce qui change, c'est tout ce qui se passe avant et pendant l'attaque.

Le phishing devient difficile à repérer

Avant, un email de phishing se repérait assez vite : fautes d'orthographe, formulation étrange, expéditeur douteux. Avec des modèles de langage détournés comme WormGPT ou FraudGPT — des versions de ChatGPT sans aucun garde-fou —, les attaquants génèrent désormais des emails qui imitent parfaitement le style d'écriture d'un collègue ou d'un supérieur, en s'appuyant sur ce qu'ils trouvent sur LinkedIn ou les réseaux sociaux de la cible.

Selon le rapport Sophos 2024, le taux de clic sur ce type de phishing généré par IA est environ trois fois plus élevé que sur un phishing classique. Autre évolution notable : les deepfakes audio et vidéo, utilisés pour

usurper l'identité d'un dirigeant et déclencher un virement frauduleux ou l'ouverture d'un accès réseau — ce qu'on appelle la fraude au président.

Le modèle Ransomware-as-a-Service (RaaS)

Ce qui m'a le plus surpris en creusant le sujet, c'est à quel point le RaaS a industrialisé la cybercriminalité. Des groupes comme LockBit, BlackCat/ALPHV ou ClOp développent une plateforme d'attaque clé en main qu'ils louent à des « affiliés », sans que ceux-ci aient besoin de compétences techniques poussées. L'IA amplifie encore ce modèle : reconnaissance réseau automatisée pour repérer les cibles vulnérables, exploitation de failles zero-day en quelques heures, génération de variantes de malwares indétectables par les antivirus classiques, et même des chatbots qui négocient directement la rançon en ajustant le montant selon la situation financière estimée de la victime.

Partie 2 — Cas concrets et impacts

Quelques attaques récentes illustrent bien l'ampleur du problème :

- Hôpital de Corbeil-Essonnes (2022, France) — système d'information paralysé pendant plusieurs semaines, rançon de 10 millions de dollars demandée, données médicales publiées sur le darkweb.
- CH de Versailles (2022, France) — attaque LockBit, retour au papier, plusieurs millions d'euros de remédiation.
- MGM Resorts (2023, États-Unis) — social engineering assisté par IA, environ 100 millions de dollars de pertes.
- Change Healthcare (2024, États-Unis) — attaque BlackCat/ALPHV, environ 190 millions de dossiers patients exposés, rançon de 22 millions de dollars payée.

Le coût d'une attaque ne se limite pas à la rançon elle-même : il faut compter la remédiation technique (reconstruction du système, forensique), la perte d'exploitation, l'impact réputationnel et parfois des amendes réglementaires. Selon Sophos, le coût moyen d'une attaque pour une PME dépasse aujourd'hui 1,85 million de dollars. On observe aussi une escalade des méthodes d'extorsion : simple chiffrage, puis double extorsion (chiffrage + vol de données), triple extorsion (+ attaque DDoS), voire quadruple extorsion (+ revente des données à des concurrents).

7 100 attaques / jour en 2024	2,7 M\$ rançon moyenne payée	42 % des attaques utilisent l'IA	< 4 h délai moyen de chiffrage
---	--	--	---

Partie 3 — Stratégies de défense

La bonne nouvelle, c'est que les stratégies de défense n'ont pas besoin d'être révolutionnaires pour être efficaces : il s'agit surtout d'appliquer sérieusement des principes déjà connus.

- La règle 3-2-1 des sauvegardes : 3 copies des données, sur 2 supports différents, dont 1 copie hors ligne (air-gap). C'est la base pour pouvoir se relever après une attaque sans payer la rançon.
- PRA et PCA : définir à l'avance le RTO (durée d'interruption tolérable) et le RPO (perte de données acceptable), puis tester les sauvegardes régulièrement plutôt que de découvrir qu'elles ne fonctionnent pas le jour où on en a besoin.
- Outils EDR / XDR : les antivirus à signature ne suffisent plus contre des malwares polymorphiques. Des solutions comme CrowdStrike Falcon ou Microsoft Defender analysent le comportement en temps réel pour repérer une activité suspecte avant le chiffrage.

- Sensibilisation humaine : puisque l'IA rend le phishing plus crédible, la formation des utilisateurs (MFA, moindre privilège, vérification des demandes inhabituelles) reste la ligne de défense la plus rentable.
- Cadre réglementaire : la directive NIS2 impose des obligations de sécurité aux entités essentielles ; le RGPD impose de notifier toute violation de données sous 72 heures, sous peine de sanctions pouvant atteindre 20 millions d'euros ou 4 % du chiffre d'affaires mondial.

Conclusion

L'intelligence artificielle n'a pas inventé de nouvelles failles : elle a surtout rendu les attaques existantes plus rapides, plus ciblées et plus difficiles à repérer. Le modèle RaaS, combiné à l'IA, a fait descendre le niveau de compétence nécessaire pour lancer une attaque dévastatrice, ce qui explique en partie la hausse continue du nombre d'incidents observée depuis 2022.

Pour un futur professionnel en SISR, cette veille confirme que la sécurité ne se joue pas seulement sur des outils techniques : c'est autant une question de sauvegardes bien pensées, de sensibilisation des utilisateurs, et de veille continue. Les méthodes des attaquants évoluent vite, et il vaut mieux les suivre que les découvrir en subissant soi-même une attaque.

Sources

Source	Type	Utilisation
daily.dev	Flux personnalisé	Suivi quotidien, filtres « ransomware », « RaaS », « AI security »
ANSSI — anssi.fr/publications	Institutionnel (France)	Définitions, statistiques, bonnes pratiques défensives
CERT-FR — cert.ssi.gouv.fr	Institutionnel (France)	Alertes et bulletins de sécurité
Sophos Threat Report	Éditeur cybersécurité	Statistiques mondiales, coûts, tendances RaaS
Microsoft Security Blog	Éditeur cybersécurité	Solutions EDR/XDR, Defender for Endpoint
ZATAZ — zataz.com	Presse spécialisée	Actualité des attaques et des groupes criminels
Bleeping Computer	Presse spécialisée	Actualité internationale des incidents
Cybermalveillance.gouv.fr	Institutionnel (France)	Conseils pratiques aux entreprises, cas concrets

Glossaire

- RaaS (Ransomware-as-a-Service) : modèle criminel où un groupe loue son infrastructure de ransomware à des affiliés.
- Phishing / spear phishing : hameçonnage par email, généralement ciblé et personnalisé quand il est généré par IA.
- Deepfake : contenu audio ou vidéo falsifié par IA pour usurper l'identité d'une personne.
- EDR / XDR : solutions de sécurité qui surveillent en temps réel les postes (EDR) ou l'ensemble du système d'information (XDR).
- Zero-day : vulnérabilité non encore corrigée par l'éditeur, exploitable immédiatement.

- Air-gap : isolation physique d'une sauvegarde, déconnectée de tout réseau.